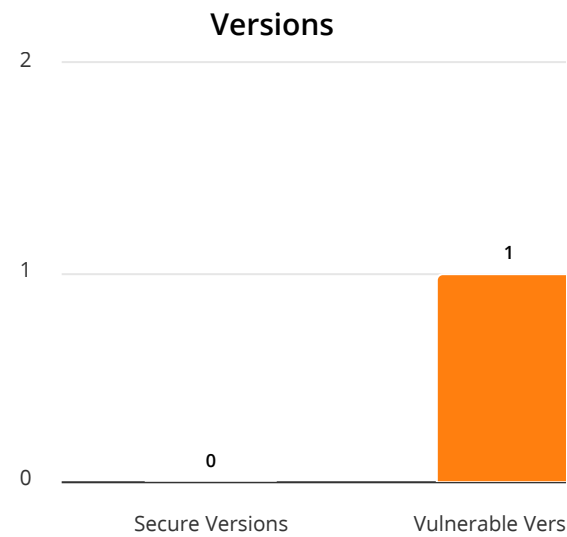
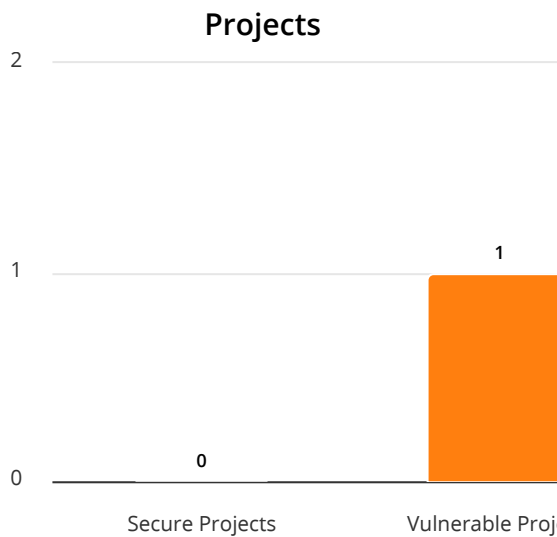




Reports ▸ Vulnerability Status

Created 29 Oct 2024 |



Ford_realtek V1

81 Vulnerabilities

Vulnerability	Overall Score	Remediation Status	CWE	Reachable	Exploit	Workaround	Solution
▼ BDSA-2022-1538	6.8	New	CWE-476	-	✓	-	-

appweb v7.2.3
 github:embedthis/appweb-4:v7.2.3

Vulnerability Description

EmbedThis Appweb contains a NULL pointer dereference vulnerability. An attacker could exploit this issue to cause a crash on the server.

▼ BDSA-2019-4635	7.5	New	CWE-94	-	✓	-	-
------------------	-----	-----	--------	---	---	---	---

goahead v4.1.3
 github:embedthis/goahead:v4.1.3

Vulnerability Description

GoAhead Web Server is vulnerable to phishing via HTTP header injection. An attacker could exploit this flaw to redirect users to a malicious website.

BDSA-2020-2305 (CVE-2020-15688)		7.7	New	CWE-294	-	-	-
✓ goahead v4.1.3 github:embedthis/goahead:v4.1.3 Vulnerability Description GoAhead Web Server is vulnerable to authentication bypass via replay attack. An unauthenticated remote attacker could exploit this to bypass authentication via capture-replay. **Note:** This issue occurs when using Digest authentication over HTTP. When used over HTTPS, replay should not be possible.							
CVE-2021-42342		9.8	New	CWE-434	-	-	-
✓ goahead v4.1.3 github:embedthis/goahead:v4.1.3 Vulnerability Description An issue was discovered in GoAhead 4.x and 5.x before 5.1.5. In the file upload filter, user form variables can be passed to CGI scripts without being prefixed with the CGI prefix. This permits tunneling untrusted environment variables into vulnerable CGI scripts.							
CVE-2021-43298		9.8	New	CWE-307	-	-	-
✓ goahead v4.1.3 github:embedthis/goahead:v4.1.3 Vulnerability Description The code that performs password matching when using 'Basic' HTTP authentication does not use a constant-time memcmp and has no rate-limiting. This means that an unauthenticated network attacker can brute-force the HTTP basic password, byte-by-byte, by recording the webserver's response time until the unauthorized (401) response.							
BDSA-2016-0044		5	New	CWE-476	-		
libjpeg-turbo 1.2.90 redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le Vulnerability Description A vulnerability exists in `libjpeg/cjpeg.c` that can cause a denial-of-service (NULL pointer dereference and application crash) condition. If the Libjpeg library is used in a system that allows users input, a maliciously crafted file allows an attacker to cause a denial-of-service (NULL pointer dereference and application crash) condition. In specific cases this may also allow the attacker to remotely execute commands.							

✓	BDSA-2016-0305	6.8	New	CWE-400, CWE-730	-	-	✓
 libjpeg-turbo 1.2.90 redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le Vulnerability Description A security audit carried out by Cure53 discovered a denial-of-service vulnerability due to CPU consumption (LJT-01-003), and a denial-of-service due to memory consumption (LJT-01-004) These vulnerability can be triggered using a crafted JPEG file that when processed by applications using Libjpeg-turbo will cause the application to hang or possibly crash. This could be a malicious website containing a JPEG that will cause the victims browser to hang and and consume excessive CPU. Closing the browser may not efficiently stop the CPU consumption and an effected user would need to force quit the application. A detailed description of this vulnerability can be found [here](https://cure53.de/pentest-report_libjpeg-turbo.pdf). ✓							
✓	BDSA-2015-0155 (CVE-2014-9092)	5.7	New	CWE-119, CWE-730	-	-	✓
 libjpeg-turbo 1.2.90 redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le Vulnerability Description LibJPEG Turbo is a JPEG image codec that uses SIMD instructions to accelerate baseline JPEG compression and decompression. It improperly handles JPEG images with malformed EXIF markers, leading to denial of service (*DoS*) in the target application by an attacker. ✓							
✓	BDSA-2018-1932	4.8	New	CWE-369	-	-	✓
 libjpeg-turbo 1.2.90 redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le Vulnerability Description libjpeg-turbo contains a division by zero vulnerability. An attacker could exploit this by crafting a malicious file which when processed by an application using the libjpeg-turbo library, will result in an application crash and a denial-of-service (*DoS*) condition.							
✓	BDSA-2018-4143	4	New	CWE-126	-	-	✓
 libjpeg-turbo 1.2.90 redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le Vulnerability Description libjpeg-turbo contains a heap based buffer over read vulnerability. An attacker could exploit this by crafting a malicious file which when processed by an application using the							

libjpeg-turbo contains a heap-based buffer over-read vulnerability. An attacker could exploit this by crafting a malicious file which when processed by an application using the libjpeg-turbo library, will result in a denial-of-service (DoS) condition via an application crash and possibly expose portions of memory.

▼	BDSA-2018-4447	3.9	New	CWE-190	-	✓	✓
---	----------------	-----	-----	---------	---	---	---

 libjpeg-turbo 1.2.90
 redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le

Vulnerability Description

Libjpeg-turbo is vulnerable to denial-of-service (DoS) attack due to a heap-based buffer overflow via a BMP image upload. This can cause the application to crash due to mishandling of resources. To exploit the attacker must trick a user into uploading a specially crafted BMP image.

▼	BDSA-2018-4794 (CVE-2018-14498)	3	New	CWE-125	-	✓	-	✓
---	------------------------------------	---	-----	---------	---	---	---	---

 libjpeg-turbo 1.2.90
 redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le

Vulnerability Description

mozjpeg and libjpeg-turbo are vulnerable to denial-of-service (DoS) due to the improper management of system memory resources. An attacker could cause a victim's instance of these applications to crash by tricking them into running the program using a crafted `.bmp` file.

	BDSA-2019-2248	3.1	New	CWE-770	-		-
--	----------------	-----	-----	---------	---	--	---

libjpeg-turbo 1.2.90
redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le

Vulnerability Description

libjpeg-turbo is vulnerable to denial-of-service (DoS) due to the mismanagement of system memory resources. An attacker could cause a victim's instance of the application to become unresponsive by tricking them into running the application using crafted input.

	BDSA-2019-3513	2.3	New	CWE-190	-		-
--	----------------	-----	-----	---------	---	--	---

libjpeg-turbo 1.2.90
redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le

Vulnerability Description

Libjpeg-turbo contains a denial-of-service (DoS) vulnerability. If an application decompresses untrusted user supplied files using Libjpeg-turbo, it may be possible for a remote

attacker to cause the process to crash.

BDSA-2020-1295

5

New

CWE-122

-

-

libjpeg-turbo 1.2.90

redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le

Vulnerability Description

It was discovered that libjpeg-turbo contains a heap-based buffer overflow vulnerability. An attacker could exploit this by supplying a crafted file to cause a crash resulting in a denial-of-service (DoS) condition.

BDSA-2020-4438

(CVE-2020-17541)

3.6

New

CWE-121

-

-

libjpeg-turbo 1.2.90

redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le

Vulnerability Description

Libjpeg-turbo is vulnerable to a denial-of-service (DoS) condition. This vulnerability allows an attacker to use a crafted `jpg` image file to crash the Libjpeg-turbo process.

BDSA-2021-4456

4.6

New

CWE-122

-

-

-

libjpeg-turbo 1.2.90

redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le

Vulnerability Description

libjpeg-turbo is vulnerable to denial-of-service (DoS) due to a heap-based buffer overflow which can be triggered by parsing a crafted file. This vulnerability causes the application to crash.

BDSA-2020-4788

6.7

New

CWE-476

-

-

libjpeg-turbo 1.2.90

redhat:libjpeg-turbo-devel/1.2.90-5.el7/ppc64le

Vulnerability Description

libjpeg-turbo is vulnerable to denial-of-service (DoS) due to the use of an invalid pointer value. An attacker could cause a vulnerable application to crash by causing that application to process a maliciously crafted input file.

	BDSA-2019-0202	5.3	New	CWE-416	-	-
lua 5.0.3 opensuse:lua50-devel/5.0.3-2.2.1/ppc64 Vulnerability Description Lua is vulnerable to denial-of-service (DoS) as it may attempt to use a variable that has already been freed. If provided with two parameter values that have the same index a Lua program may crash under certain circumstances when performing a value join operation.						
	BDSA-2020-1807	3.9	New	CWE-122, CWE-416	-	-
lua 5.0.3 opensuse:lua50-devel/5.0.3-2.2.1/ppc64 Vulnerability Description Lua is vulnerable to a use-after-free condition and multiple heap-based buffer overflow conditions due to how the garbage collection process interacts with the resizing of a stack. An attacker could trick a victim user into executing a crafted `.lua` file to cause a use-after-free error or buffer overflow, potentially affecting the stability of the Lua interpreter.						
	BDSA-2020-1850	6.7	New	CWE-229, CWE-664	-	-
lua 5.0.3 opensuse:lua50-devel/5.0.3-2.2.1/ppc64 Vulnerability Description Lua is vulnerable to a denial-of-service (DoS) condition via a segmentation fault in the `changedline()` function in `ldebug.c`.						
	BDSA-2020-2058	3	New	CWE-121	-	-
lua 5.0.3 opensuse:lua50-devel/5.0.3-2.2.1/ppc64 Vulnerability Description Lua is vulnerable to denial-of-service (DoS) due to improper validation of user-supplied input. An attacker could exploit this vulnerability by supplying a victim with a maliciously crafted file.						

BDSA-2020-2093	6.5	New	CWE-476	-	-	-
lua 5.0.3 opensuse:lua50-devel/5.0.3-2.2.1/ppc64 Vulnerability Description Lua contains a NULL pointer dereference vulnerability. Successfully exploiting this issue may allow attackers to cause a denial-of-service (DoS).						
BDSA-2020-2099	5.9	New	CWE-200	-		-
lua 5.0.3 opensuse:lua50-devel/5.0.3-2.2.1/ppc64 Vulnerability Description Lua is vulnerable to information disclosure via memory access violations due to how it handles the interaction between barriers and the sweep phase in the garbage collector.						
BDSA-2022-0976	7.4	New	CWE-122, CWE-126	-		-
lua 5.0.3 opensuse:lua50-devel/5.0.3-2.2.1/ppc64 Vulnerability Description Lua is vulnerable to denial-of-service (DoS) and information disclosure issues due to a missing `luaK_exp2anyregup()` call. An attacker could supply crafted input to a system that compiles untrusted Lua code in order to negatively impact stability or potentially read information from memory.						
BDSA-2022-1825	5.6	New	CWE-120	-		-
lua 5.0.3 opensuse:lua50-devel/5.0.3-2.2.1/ppc64 Vulnerability Description Lua is vulnerable to denial-of-service (DoS) due to improper error handling which can lead to a stack overflow. An attacker could exploit this vulnerability by supplying a system with a maliciously crafted script.						
BDSA-2020-0565 (CVE-2020-10941)	4.6	New	CWE-385	-		-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Arm Mbed TLS is vulnerable to a cache side-channel attack. An attacker can recover a private RSA key if they have fine grained measurements to cache usage at the time an RSA key is being imported.

BDSA-2020-0822
(CVE-2020-10932)

5.2

New

CWE-310

-

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS is vulnerable to information disclosure due to the existence of a side channel. An attacker could obtain the private ECDSA key that is being used in a TLS session by observing a number of signature operations.

BDSA-2020-2270
(CVE-2020-16150)

4.8

New

CWE-201

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

mbed TLS is vulnerable to a side channel attack when decrypting and authenticating (D)TLS record in a connection using a CBC ciphersuite. A local attacker could use this in order to recover portions of the plaintext of a (D)TLS record. **Note:** This vulnerability only affects systems which are decrypting/authenticating (D)TLS record in a connection using a CBC ciphersuite without the Encrypt-then-Mac extension `RFC 7366`

BDSA-2019-5024
(CVE-2019-16910)

5.2

New

CWE-208

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

The deterministic ECDSA implementation in the Arm Mbed TLS project is vulnerable to side-channel attacks. A remote attacker could leverage this to recover the private key if the end application can be made to sign the same message repeatedly.

BDSA-2019-5028 (CVE-2019-18222)	3.7	New	CWE-200	-	-	-
mbed TLS 2.16.0 ubuntu:mbedtls/2.16.0-1						
Vulnerability Description Mbed TLS and Mbed Crypto are vulnerable to side channel attacks because of lack of protection measures. An attacker could exploit this flaw to gain access to sensitive information like private keys.						
BDSA-2021-2103 (CVE-2021-24119)	3.6	New	CWE-524	-	-	-
mbed TLS 2.16.0 ubuntu:mbedtls/2.16.0-1						
Vulnerability Description Mbed TLS is vulnerable to side channel attacks because a non-constant time implementation is used for `base64` `PEM` file decoding. An attacker with admin privileges could exploit this in order to gain knowledge about secret RSA keys through tracking of the accessed cache during key decoding.						
BDSA-2021-2129 (CVE-2020-36426)	4.6	New	CWE-126	-	-	-
mbed TLS 2.16.0 ubuntu:mbedtls/2.16.0-1						
Vulnerability Description mbed TLS contains a buffer over-read vulnerability. Successfully exploiting this issue may allow attackers to trigger a denial-of-service (DoS) condition and crash the application.						
BDSA-2020-4551 (CVE-2020-36423)	6.5	New	CWE-310, CWE-385	-	-	-
mbed TLS 2.16.0 ubuntu:mbedtls/2.16.0-1						
Vulnerability Description mbed TLS is vulnerable to sensitive data exposure due to the existing mitigation for the Lucky 13 timing side-channel attacks being insufficient. This can allow an attacker to use a timing attack in order to recover plaintext.						

a timing attack in order to recover plaintext.

BDSA-2020-4552
(CVE-2020-36425)

6.5

New

CWE-229

-

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

mbed TLS incorrectly handles the Certificate Revocation List (CRL) when checking X.509 CRLs. This could allow an attacker to be able to control if their certificate is revoked or not.

BDSA-2020-4556
(CVE-2020-36424)

4.5

New

CWE-208, CWE-385

-

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

mbed TLS is vulnerable to information exposure via a side channel timing attack. This can allow a local attacker with access to precise enough timing and memory access information to recover the private keys used in RSA or static Diffie-Hellman operations.

BDSA-2020-4553
(CVE-2020-36422)

4.5

New

CWE-310, CWE-385

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

mbed TLS is vulnerable to information exposure via a side channel timing attack. This can allow an attacker with access to precise enough timing and memory access information to fully recover the ECC private key.

BDSA-2020-4554
(CVE-2020-36421)

4.5

New

CWE-310, CWE-385

-

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

mbed TLS is vulnerable to information exposure via a side channel timing attack. This can allow an attacker to obtain an RSA private key used in a secure enclave.

BDSA-2020-4599
(CVE-2020-36476)

6.5

New

CWE-668

- - -

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS contains a missing zeroization vulnerability relating to plaintext buffers within ``mbedtls_ssl_read()``. An attacker could exploit this in order to cause integrity issues.

BDSA-2020-4598
(CVE-2020-36475)

6.5

New

CWE-400

- - -

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS is vulnerable to a denial-of-service (DoS) issue due to a flaw in how calculations are performed by the ``mbedtls_mpi_exp_mod()`` function. An attacker could supply a crafted input in order to cause DoS effects when generating Diffie-Hellman key pairs.

BDSA-2020-4600
(CVE-2020-36478)

6.7

New

CWE-295

- -

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS is vulnerable to improper certificate validation due to a missing tag check within the ``x509_crt_parse_der_core()`` function. An attacker could exploit this in order to cause a certificate to be improperly validated.

BDSA-2021-3822
(CVE-2021-44732)

7.1

New

CWE-415, CWE-664

- -

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS is vulnerable to memory corruption due to the improper management of system memory resources. An attacker could cause a double-free by triggering an error in the library's SSL session handling functionality. This could allow the attacker to cause the program to crash. The attacker may also be able to leverage this issue in order to modify data or execute arbitrary code, but this has not been demonstrated.

BDSA-2021-3841

4.6

New

CWE-323

-

-

-

mbed TLS 2.16.0

ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS is vulnerable to policy bypass due to improper processing of nonce tokens in output buffers within the functions ``psa_cipher_generate_iv()`` and ``psa_cipher_encrypt``. This could allow access of nonce tokens in memory.

BDSA-2021-4268
(CVE-2021-43666)

6.5

New

CWE-20

-

-

-

mbed TLS 2.16.0

ubuntu:mbedtls/2.16.0-1

Vulnerability Description

mbed TLS is vulnerable to denial-of-service (DoS) due to the improper validation of user-provided input when entering a password. An attacker could exploit this vulnerability and cause the application to crash by entering a NULL password or non-zero length password.

BDSA-2022-1976
(CVE-2022-35409)

5.7

New

CWE-126

-

-

mbed TLS 2.16.0

ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Certain configurations of DTLS server (Mbed TLS) contain a buffer over-read issue which can be triggered by sending an invalid ClientHello message. The DTLS server would then read up to 255 bytes of the heap buffer past the end of the message. Apart from the disclosed bytes, the vulnerability can also result in a server crash.

BDSA-2022-3621
(CVE-2022-46393)

7.1

New

CWE-122, CWE-126

-

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

A heap-based buffer over-read and overwrite has been discovered in DTLS server of Mbed TLS. This is a result of mismanagement of system resources and leads to corruption of the process memory. An attacker could exploit this by sending a crafted input to the DTLS server, that may disclose bytes from the application memory or crash the application.

BDSA-2022-3626
(CVE-2022-46392)

4.5

New

CWE-385

-

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS is vulnerable to a timing side-channel attack. An attacker who is able to gather precise information from memory accesses may be able to recover an RSA private key if they can observe the victim perform a private key operation.

BDSA-2022-3692

7.1

New

CWE-122

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

mbedtls is vulnerable to a denial-of-service (DoS) condition. This allows an unauthenticated remote attacker to send crafted DTLS packets that may cause an application or system using mbedtls to crash.

BDSA-2021-4767
(CVE-2021-36647)

5.4

New

CWE-288

-

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS contains a private key disclosure vulnerability due to poor cryptographic security. A local attacker could exploit this issue by running Mbed TLS on an untrusted operating system and carrying out a side-channel attack which can recover the RSA private keys previously used by another user. This could lead to the disclosure of sensitive information.

BDSA-2023-2701
(CVE-2023-43615)

7.1

New

CWE-126

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS contains a buffer over-read vulnerability. An attacker that has successfully completed the handshake using a `null-cipher` or `RC4 cipher suite` could exploit this by sending a malformed encrypted (or null-encrypted) record in order to cause a denial-of-service (DoS) condition or disclose sensitive information if the platform has not been memory protected. **Note:** * The vulnerability is not present in the default build of Mbed TLS. It is only present if the compile-time configuration enables the vulnerable cipher suites. * A firewall that prevents the negotiation of null-cipher or RC4 cipher suites will prevent the vulnerability from being exploited by traffic that goes through the firewall. * Only weak cipher suites are affected: cipher suites using the null cipher (`TLS\_xxx\_WITH\_NULL\_hhh`, with authentication but not encryption) or RC4 (`TLS\_xxx\_WITH\_RC4\_128\_hhh`, a weak and deprecated cipher, no longer supported after Mbed TLS 3.0). Those cipher suites are disabled in the default build-time configuration. * Applications that only accept TLS 1.3 are not affected.

BDSA-2023-3632
(CVE-2023-52353)

7.4

New

CWE-477

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS does not handle negotiable TLS versions correctly during connections. An attacker could exploit this to cause instability in `programs/ssl/ssl\_server2` and refuse TLS 1.3 connections from a peer if the same peer previously used TLS 1.2 to establish a connection. **Note:** * A maintainer has mentioned that the server side does not have version negotiation yet. This is a documented limitation of TLS 1.3 in the library, which is a feature still in development. * This is still relevant in 3.5 where version negotiation is supported on the server side. * This is a similar issue to [#8694](https://github.com/Mbed-TLS/mbedtls/issues/8694).

BDSA-2024-0233
(CVE-2024-23170)

4.8

New

CWE-327

-

-

mbed TLS 2.16.0
ubuntu:mbedtls/2.16.0-1

Vulnerability Description

Mbed TLS suffers from an information disclosure vulnerability. An attacker in a locally adjacent network or local on an affected install could recover the plaintext of sensitive contents if they can observe timing of the decryption of said contents. The attacker must send a large volume of requests to attempt this decryption. This vulnerability can be exploited with a "Marvin Attack" as reported by Hubert Kario.

BDSA-2024-0249

5.1

New

CWE-100

-

(CVE-2024-23775)	5.1	New	CWE-190	-	-
mbed TLS 2.16.0 ubuntu:mbedtls/2.16.0-1 Vulnerability Description Mbed TLS is vulnerable to denial-of-service (DoS) due the presence of an integer overflow issue. An attacker could exploit this vulnerability by passing maliciously crafted input to with a manipulated x509 extension length value. This could result in DoS by a segmentation fault.					
BDSA-2024-0759	7.1	New	CWE-126, CWE-327	-	-
mbed TLS 2.16.0 ubuntu:mbedtls/2.16.0-1 Vulnerability Description Mbed TLS improperly handles the use of shared memory when communicating between the PSA Crypto API callers and implementations. This could allow for untrusted domains to access shared memory which could lead to an attacker potentially causing memory corruption via several security breaches. They could also leverage this to achieve more serious confidentiality, integrity and availability impacts. Note: Applications where Mbed TLS functions do not receive parameters that are in shared memory are unaffected. A crypto server relying on the standard PSA Firmware Framework 1.0 APIs is not affected.					
BDSA-2024-6097 (CVE-2024-45157)	6.4	New	CWE-327	-	-
mbed TLS 3.6.0 debian:mbedtls/3.6.0-2 Vulnerability Description Mbed TLS is vulnerable to exposing users to unknown side-channel attack risk, if administrators set the `MBEDTLS_PSA_HMAC_DRBG_MD_TYPE` flag to use `HMAC_DRBG` the code actually uses `CTR_DRBG` instead which presents additional risk of side-channel attacks and provides a false representation of system operations. While an attacker is unlikely to exploit this vulnerability, it could introduce additional attack vectors (side-channel) which administrators had not accounted for potentially affecting risk profiles and policies.					
BDSA-2024-6092 (CVE-2024-45159)	8.5	New	CWE-295	-	-
mbed TLS 3.6.0 debian:mbedtls/3.6.0-2 Vulnerability Description					

Vulnerability Description

Mbed TLS is vulnerable to authentication bypass via improper checks for a valid certificate in the `mbedtls\_ssl\_get\_verify\_result()` function. An attacker could exploit this vulnerability to access TLS client authentication services with a certificate that is approved for other functionality but not TLS client authentication, allowing them to launch further attacks using this service. **Note:** This only impacts TLS 1.3 optional client authentication. Mandatory authentication (MBEDTLS_SSL_VERIFY_REQUIRED) is not affected (it will correctly abort the handshake with a fatal alert if the client certificate is absent or invalid). TLS 1.2 authentication is not affected. TLS 1.3 server authentication is not affected, as before 3.6.1 it could not be made optional.

BDSA-2024-6098

7.1

New

CWE-120

-

-

mbed TLS 3.6.0
debian:mbedtls/3.6.0-2

Vulnerability Description

Mbed TLS is vulnerable to stack buffer overflow due to missing validation of the `bits` parameter when used in the `mbedtls\_ecdsa\_der\_to\_raw` and `mbedtls\_ecdsa\_raw\_to\_der` functions. An attacker could exploit this vulnerability to call the affected functions with arbitrary inputs potentially leading to other memory corruption exploits causing serious confidentiality, integrity and availability impacts.

BDSA-2024-7299

7.1

New

CWE-124

-

-

mbed TLS 3.6.0
debian:mbedtls/3.6.0-2

Vulnerability Description

Mbed TLS contains a buffer underflow issue in two of its `pk\_write` functions. A remote attacker could leverage this to cause memory corruption in the application, potentially resulting in serious confidentiality, integrity and availability impacts.

BDSA-2024-7299

7.1

New

CWE-124

-

-

mbed TLS 3.6.1
opensuse:mbedtls/3.6.1-1.0.2.1.sr20240901/i586

Vulnerability Description

Mbed TLS contains a buffer underflow issue in two of its `pk\_write` functions. A remote attacker could leverage this to cause memory corruption in the application, potentially resulting in serious confidentiality, integrity and availability impacts.

BDSA-2024-6905

6.5

New

CWE-119

-

-

-

[Embargoed](#)

Mozilla Firefox 131.0b3
unknown:undefined

Vulnerability Description

Mozilla Firefox, Firefox ESR, and Thunderbird are vulnerable to memory corruption due to insufficient validation checks in the `GMPVideoi420FrameImpl`, `ChromiumCDMParent`, and JIT `Architecture-arm64` components. The vendor has stated that they presume with enough effort some of these flaws could be exploited to run arbitrary code. This has been considered when scoring the impact these memory safety bugs may have on a system.

BDSA-2024-6917

6.5

New

CWE-119

-

-

-

Embargoed

Mozilla Firefox 131.0b3
unknown:undefined

Vulnerability Description

Mozilla Firefox, Firefox ESR, and Thunderbird are vulnerable to memory corruption due to the presence of multiple undisclosed memory safety flaws. **Note:** The vendor has stated that they presume with enough effort some of these flaws could be exploited to run arbitrary code. This has been considered when scoring the impact these memory safety bugs may have on a system.

BDSA-2024-6922

6.5

New

CWE-119

-

-

-

Embargoed

Mozilla Firefox 131.0b3
unknown:undefined

Vulnerability Description

Mozilla Firefox and Thunderbird are vulnerable to memory corruption due to the presence of a memory safety flaw in the `js/src/wasm/WasmStubs.cpp` file. **Note:** the vendor has stated that they presume with enough effort this flaw could be exploited to run arbitrary code. This has been considered when scoring the impact this memory safety bug may have on a system.

BDSA-2024-6984

5.7

New

CWE-1021

-

-

-

Embargoed

Mozilla Firefox 131.0b3
unknown:undefined

Vulnerability Description

Mozilla Firefox is vulnerable to clickjacking due to a missing delay in the directory upload UI. This could allow an attacker to trick a user into granting permission, potentially bypassing directory upload security measures.

BDSA-2024-7123 (CVE-2024-9680)

[Embargoed](#)

8.9

New

CWE-416

-

-

Mozilla Firefox 131.0b3
unknown:undefined

Vulnerability Description

Mozilla Firefox and Firefox ESR are vulnerable to remote code execution (RCE) due to a use after free bug in the Animation timelines. This vulnerability can be exploited by visiting a crafted web page. **Note:** this vulnerability is known to be exploited in the wild.

BDSA-2024-7231

[Embargoed](#)

7.1

New

CWE-758

-

-

-

Mozilla Firefox 131.0b3
unknown:undefined

Vulnerability Description

Firefox is vulnerable to memory corruption due to undefined behavior in the selection node cache. An attacker could exploit this by manipulating the cache in order to cause an exploitable crash.

BDSA-2023-3046 (CVE-2023-5678)

4.6

New

CWE-20, CWE-407

-

-

-

OpenSSL 1.1.1w
long_tail:git://git.openssl.org/openssl#OpenSSL_1_1_1w

Vulnerability Description

When the key or parameters used in functions associated with generating and checking X9.42 DH keys originate from an untrusted source it may lead to denial-of-service (DoS) in OpenSSL. Crafted values for these keys and parameters can cause long delays in calculations in the related functions, potentially degrading performance of the application. **Note:** - The `pkey` command line application when using the `-pubcheck` argument and the `genpkey` command line application are both also affected by this issue, - The OpenSSL SSL/TLS implementation is not affected by this issue, - The OpenSSL 3.0 and 3.1 FIPS providers are not affected by this issue.

BDSA-2024-0202 (CVE-2024-0727)

6.5

New

CWE-476

-

-

-

OpenSSL 1.1.1w
long_tail:git://git.openssl.org/openssl#OpenSSL_1_1_1w

Vulnerability Description

Applications using OpenSSL to process PKCS12 files from untrusted sources may be subject to a potential denial-of-service (DoS) attack. This occurs as a result of a NULL pointer dereference due to missing checks for NULL values that may be present in the file format. A remote attacker could host a malicious PKCS12 file that, if processed by an application using OpenSSL, could trigger this vulnerability and result in DoS.

BDSA-2024-0977

6.5

New

CWE-400

-

-

-

OpenSSL 1.1.1w
long_tail:git://git.openssl.org/openssl#OpenSSL_1_1_1w

Vulnerability Description

OpenSSL is vulnerable to denial-of-service (DoS) due to improper management of caching for TLS v1.3 sessions. This could allow an attacker to cause a TLS server supporting v1.3 to consume excessive memory and crash, if the non-default `SSL\_OP\_NO\_TICKET` is configured and the `early\_data\_support` option is not in use.

BDSA-2024-3135

6.8

New

CWE-416

-

-

-

OpenSSL 1.1.1w
long_tail:git://git.openssl.org/openssl#OpenSSL_1_1_1w

Vulnerability Description

OpenSSL contains a memory corruption vulnerability due to a use-after-free issue in the API function `SSL\_free\_buffers`. Only applications that invoke this function directly are affected, OpenSSL maintainers believe this to be a small percentage of applications using OpenSSL. An attacker that can engineer a situation where `SSL\_free\_buffers` is called on a buffer still in use could trigger the use-after-free. This could lead to impacts ranging from denial-of-service (DoS), data corruption, to potentially arbitrary code execution.
Note: The FIPS modules in versions 3.3.X, 3.2.X, 3.1.X and 3.0.X are not affected by this issue.

BDSA-2022-1122
(CVE-2022-27404)

5.5

New

CWE-122

-

-

The FreeType Project 2.11.0
anaconda:freetype/2.11.0-h70c0345_0-linux-64

Vulnerability Description

FreeType does not properly validate user input received via the `FT\_New\_Face()` function. An attacker could submit malicious input to this function using a crafted file and crash the application. This could cause a denial-of-service (DoS).

BDSA-2022-1123

BDSA-2022-1123 (CVE-2022-27405)	5	New	CWE-20	-	-	-
The FreeType Project 2.11.0 anaconda:freetype/2.11.0-h70c0345_0-linux-64 Vulnerability Description FreeType does not properly validate user input received via the `FT_Set_Char_Size()` function. An attacker could submit malicious input to this function using a crafted file and crash the application. This could cause a denial-of-service (DoS).						
BDSA-2022-1124 (CVE-2022-27406)	5	New	CWE-20	-	-	-
The FreeType Project 2.11.0 anaconda:freetype/2.11.0-h70c0345_0-linux-64 Vulnerability Description FreeType does not properly validate user input received via the `FT_Set_Char_Size()` function. An attacker could submit malicious input to this function using a crafted file and crash the application. This could cause a denial-of-service (DoS).						
BDSA-2022-1494	5.9	New	CWE-122	-	-	-
The FreeType Project 2.11.0 anaconda:freetype/2.11.0-h70c0345_0-linux-64 Vulnerability Description FreeType Demo Programs is vulnerable to an out-of-bounds write operation due to the improper management of dynamically allocated memory resources. An attacker could potentially modify data in memory, or cause the application to crash, by causing it to process maliciously crafted input data.						
BDSA-2022-1269 (CVE-2022-30295)	7.1	New	CWE-330	-	-	-
uClibc-ng - Embedded C library v1.0.40 github:wbx-github/uclibc-ng:v1.0.40 Vulnerability Description uClibc and uClibc-ng is vulnerable to DNS cache poisoning due to insufficiently random DNS transaction IDs. This could allow an attacker to perform DNS cache poisoning attacks.						

BDSA-2022-2866 (CVE-2022-29503)	7.1	New	CWE-119	-	-	-
uClibc-ng - Embedded C library v1.0.40 github:wbx-github/uclibc-ng:v1.0.40						
Vulnerability Description uClibc contains a memory corruption vulnerability. An attacker able to create a large amount of threads could overwrite executable program memory.						
BDSA-2016-1107 (CVE-2016-9840) Zero-click RCE	6.8	New	CWE-823	-	-	-
zlib 1.2.3 alt_linux:gears/z/zlib.git:v1.2.3						
Vulnerability Description Zlib violates the C standard by performing out-of-bounds pointer arithmetic. To exploit, an attacker could trick a user into opening a specially crafted file with the component.						
BDSA-2016-1110 (CVE-2016-9843)	6.8	New	CWE-710, CWE-758	-	-	-
zlib 1.2.3 alt_linux:gears/z/zlib.git:v1.2.3						
Vulnerability Description Zlib violates the C standard by decrementing a pointer before its allocated memory. This could result in undefined behavior leading to a denial-of-service condition. To exploit, an attacker could trick a user into opening a specially crafted file with the component.						
BDSA-2016-1108 (CVE-2016-9841) Zero-click RCE	6.8	New	CWE-823	-	-	-
zlib 1.2.3 alt_linux:gears/z/zlib.git:v1.2.3						
Vulnerability Description Zlib violates the C standard by performing out-of-bounds pointer arithmetic. To exploit, an attacker could trick a user into opening a specially crafted file with the component.						

BDSA-2018-5271 (CVE-2018-25032)	7.1	New	CWE-787	-	-	-
zlib 1.2.3 alt_linux:gears/z/zlib.git:v1.2.3 Vulnerability Description zlib is vulnerable to memory corruption due to the improper management of system memory resources. An attacker could potentially modify data in a vulnerable application's memory, or cause the application to crash, by causing it to process a maliciously crafted input file. It might also be possible for an attacker to leverage this vulnerability to recover sensitive data from memory.						
BDSA-2022-2183 (CVE-2022-37434)	5.9	New	CWE-122, CWE-20	-		-
zlib 1.2.3 alt_linux:gears/z/zlib.git:v1.2.3 Vulnerability Description zlib is vulnerable to a heap-based buffer overflow issue due to how the <code>`inflate()`</code> function does not correctly validate if there is enough space in a destination buffer before performing a <code>`zmemcpy()`</code> operation. When getting a gzip header extra field using <code>`inflate()`</code>, the overflow can occur if the extra field is larger than the space the user provided with <code>`inflateGetHeader()`</code> and if multiple calls of <code>`inflate()`</code> deliver the extra header data. This could lead to data being written beyond the end of the buffer resulting in instability. Note: This issue only impacts applications that call <code>`inflateGetHeader()`</code>.						
BDSA-2023-2778 (CVE-2023-45853)	6.8	New	CWE-122	-	-	-
zlib 1.2.3 alt_linux:gears/z/zlib.git:v1.2.3 Vulnerability Description The experimental MiniZip package for zlib is vulnerable to a memory corruption issue due to the presence of a heap-based buffer overflow flaw in the <code>`zipOpenNewFileInZip4_64()`</code> function that can occur as a result of an integer overflow. An attacker could supply a crafted ZIP file with a long <code>`filename`</code>, <code>`comment`</code>, <code>`size_extrafield_local`</code> or <code>`size_extrafield_global`</code> value to an application using MiniZip in order to trigger the integer overflow issue and cause a buffer overflow to occur. Such overflows could potentially be abused to lead to serious confidentiality, integrity or availability impacts. Note: MiniZip is an unofficial, third party contribution for the zlib library and is thus not fully supported.						